

HACKING WORLD!

腾讯安全沙龙第9期 • 深圳站

→ 深圳南山文体中心聚橙剧院·小剧院

📅 07/04 ⌚ 13:30



生物黑客



金融黑客



社交黑客



身体黑客



物理黑客



思维黑客



从无线电到DMA: 近源渗透实战技术导览

杨文韬 | *PushEAX* | 2026.7.4

About Me

云鼎实验室 | 腾讯云安全

杨文韬 PushEAX

> 硬件安全 / 物联网安全 / 近源渗透

对近源渗透、硬件安全有较多研究。

开发并开源多个相关工具：GrabAccess、USBKeylogger、USBAirborne、Telescreen等。

在 KCON、腾讯安全沙龙、看雪论坛沙龙等会议发表议题。

☒ CORE_MODULES.EXE

15914048247

pushe4x@gmail.com

<https://github.com/Push3AX/>

• SYS.ADMIN // ONLINE



01001000 01000001 01000011 01001011 01000101 01010010 00100000 01010000 01010010 01001111 01000110 01001001 01001100 01000101 00100000 01001001 01001110 01001001 01010100 01001001 01000001 01001100 01001001 01011010 01000101 0100001110 00101110 00101110 00101110 00100000 01010011 01011001 01010011 01010100 01000101 01001101 00100000 01001111 01001110 01001100 01001001 01001110 01000101 00100000 01001000 01000001 01000011 01001011 01000101 01010010 00100000 01010001

開學第一天的數學老師：



同學們我們進度已經落後了

在现实世界接近或接触被测对象的安全测试



Wi-Fi安全 – 使用BW16-Tools快速抓包

基于BW16-Kit RTL8720DN 的无线安全测试工具

- 支持2.4Ghz / 5Ghz
- 解除身份认证(Deauth)
- 密码钓鱼
- 认证/关联帧洪水攻击
- 蓝牙弹窗攻击
- 抓取WAP/WPA2握手包



选择AP/SSID

常规攻击[Attack]

快速扫描[Scan]

深度扫描 DeepScan

快速抓包[Capture]

启动[Web UI]

快速抓包进行中...
目标: TP-LINK...
握手帧: 2/4
管理帧: 6/10
时间: 18s

密码钓鱼[Phishing]

连接/信道干扰[CI]

广播黑洞[BBH]

> 全选 <

[*] TP-LINK_5G 5G

测试网络 24

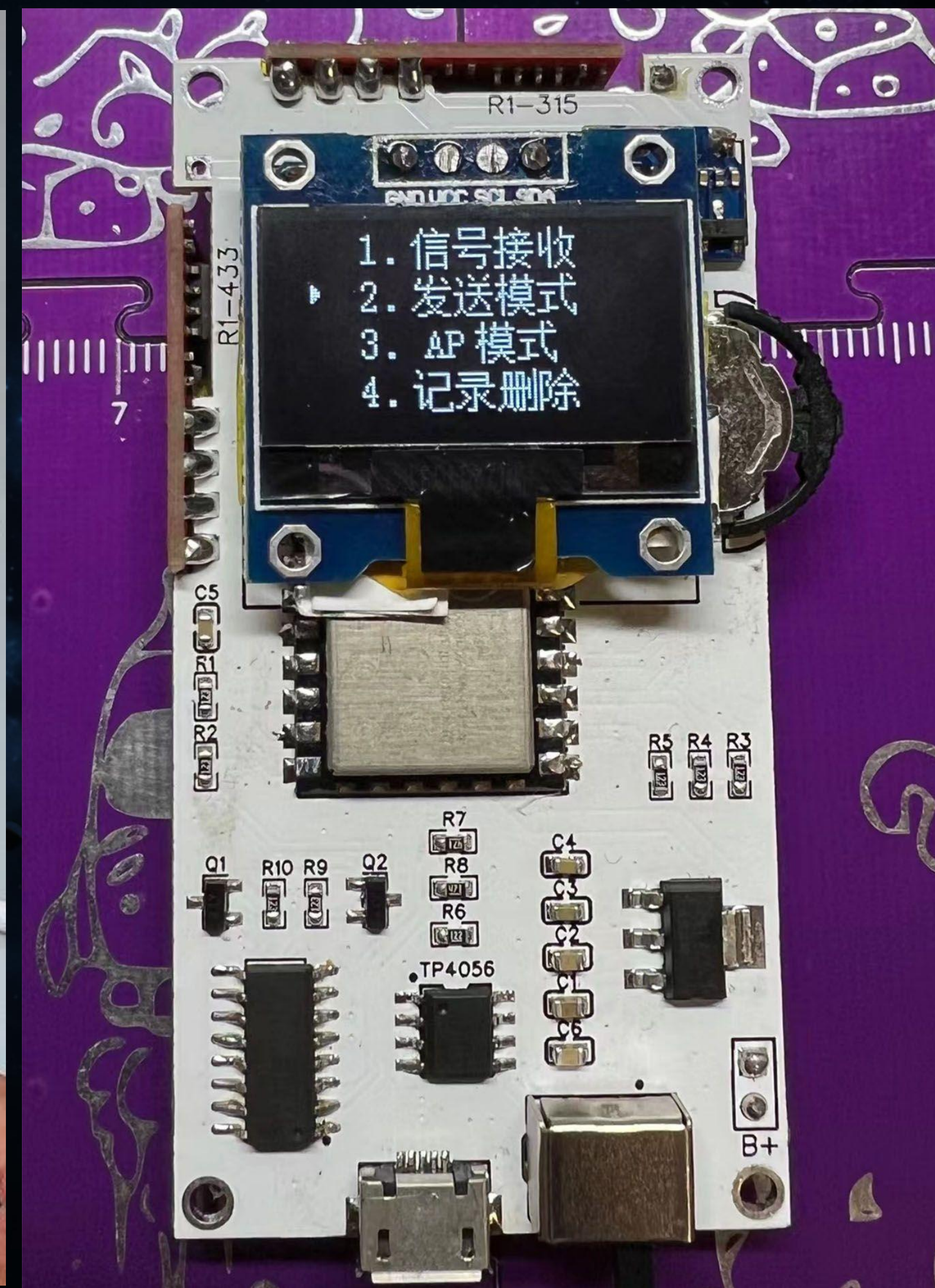
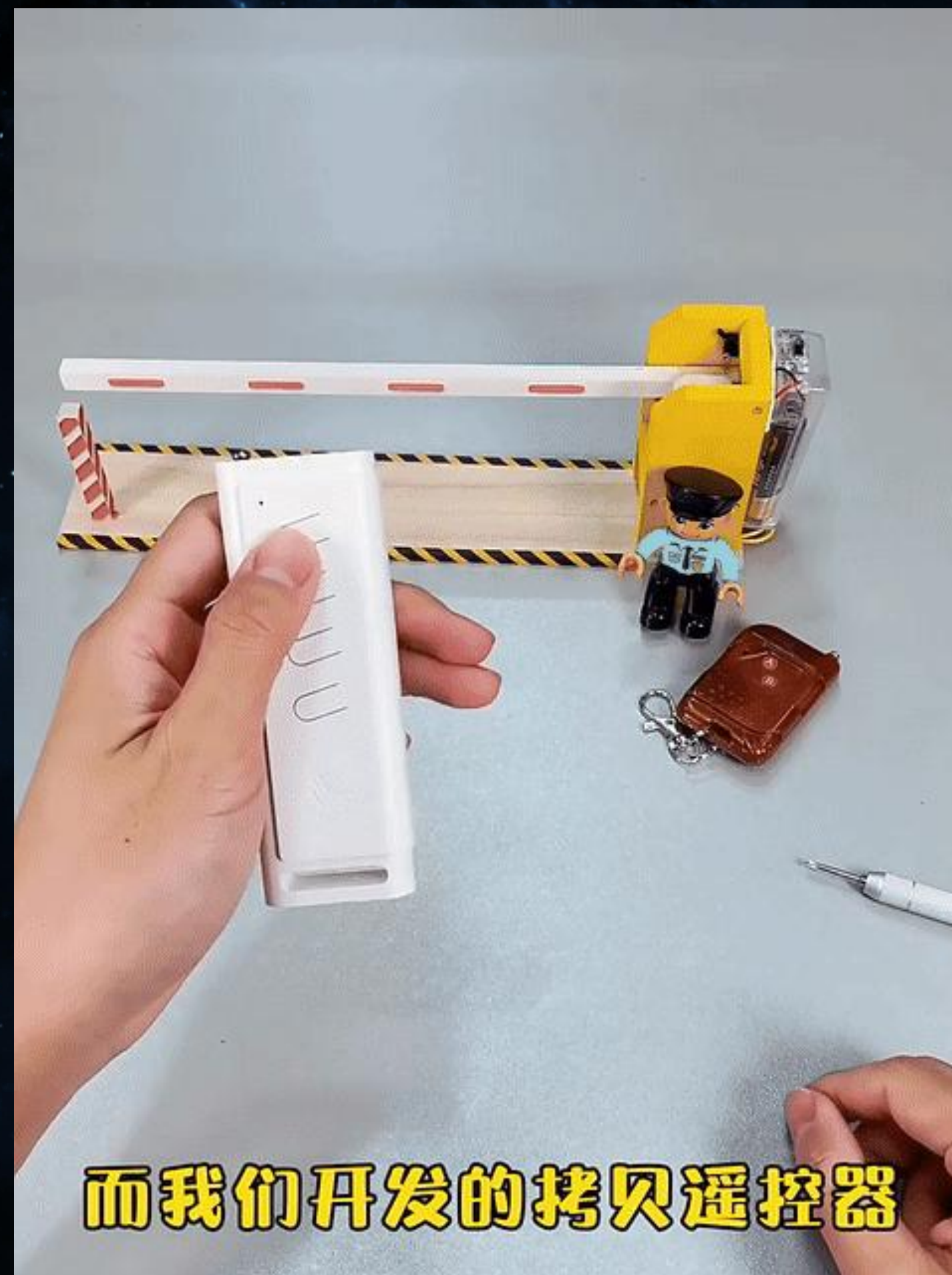
IoT-Lab-Long-SSID 24

抓包完成!
握手帧: 4/4
管理帧: 10/10
用时: 31s

启动Web服务

无线电门禁重放攻击

- 支持315Mhz / 433Mhz
- 录制、重放无线电门禁信号
- 信号干扰
- 无需跳频
- 较好适配国内常见协议
- 但不支持其它协议，不支持RAW
- 价格较为低廉



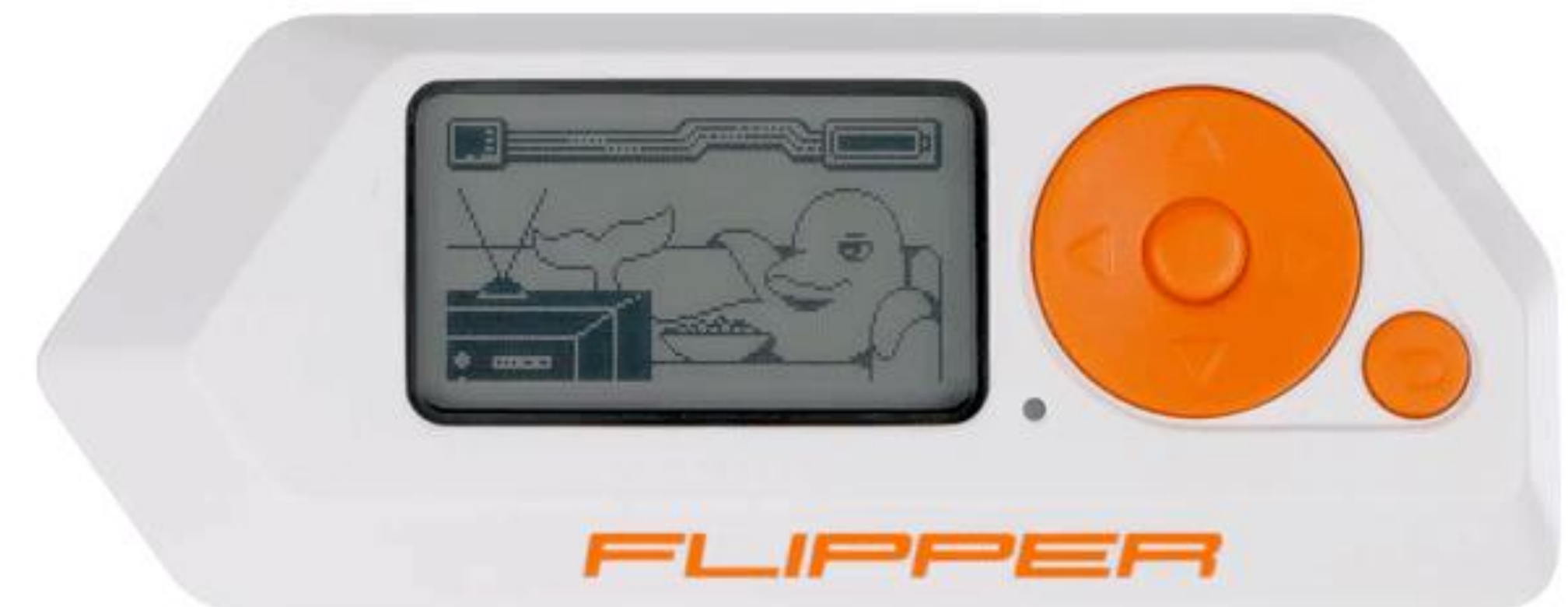
更高级的无线攻防 – Flipper Zero

两者皆支持的功能:

- 录制、重放无线电锁信号
[仅PT2262固定码]
- 干扰无线电锁

仅Flipper Zero支持的功能:

- 录制、重放无线电锁
[几乎所有协议, 支持RAW录制]
- 攻击滚动码系统
[RollJam / KeeLoq 算法缺陷]
- 爆破无线电锁
- 频率分析



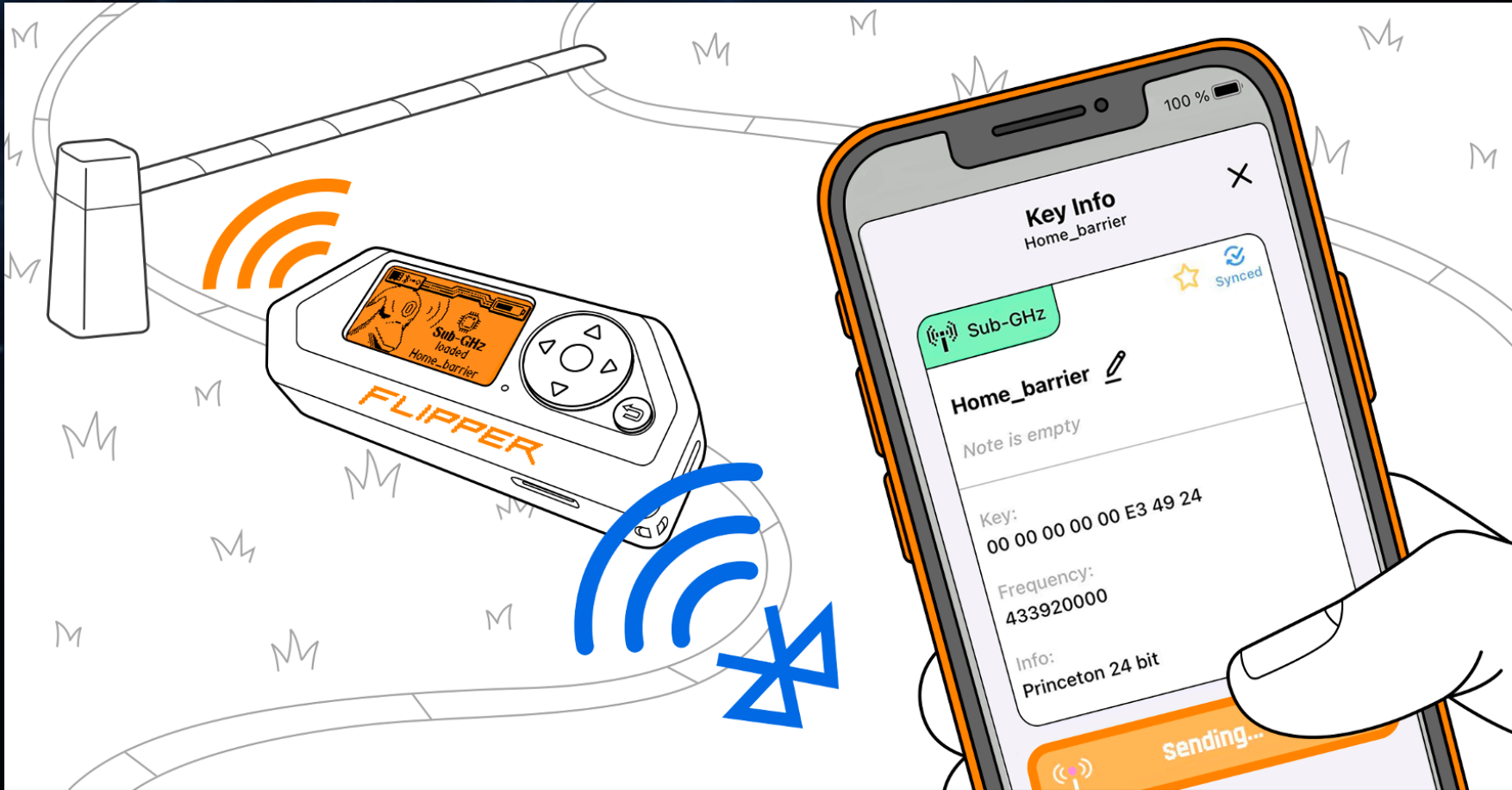
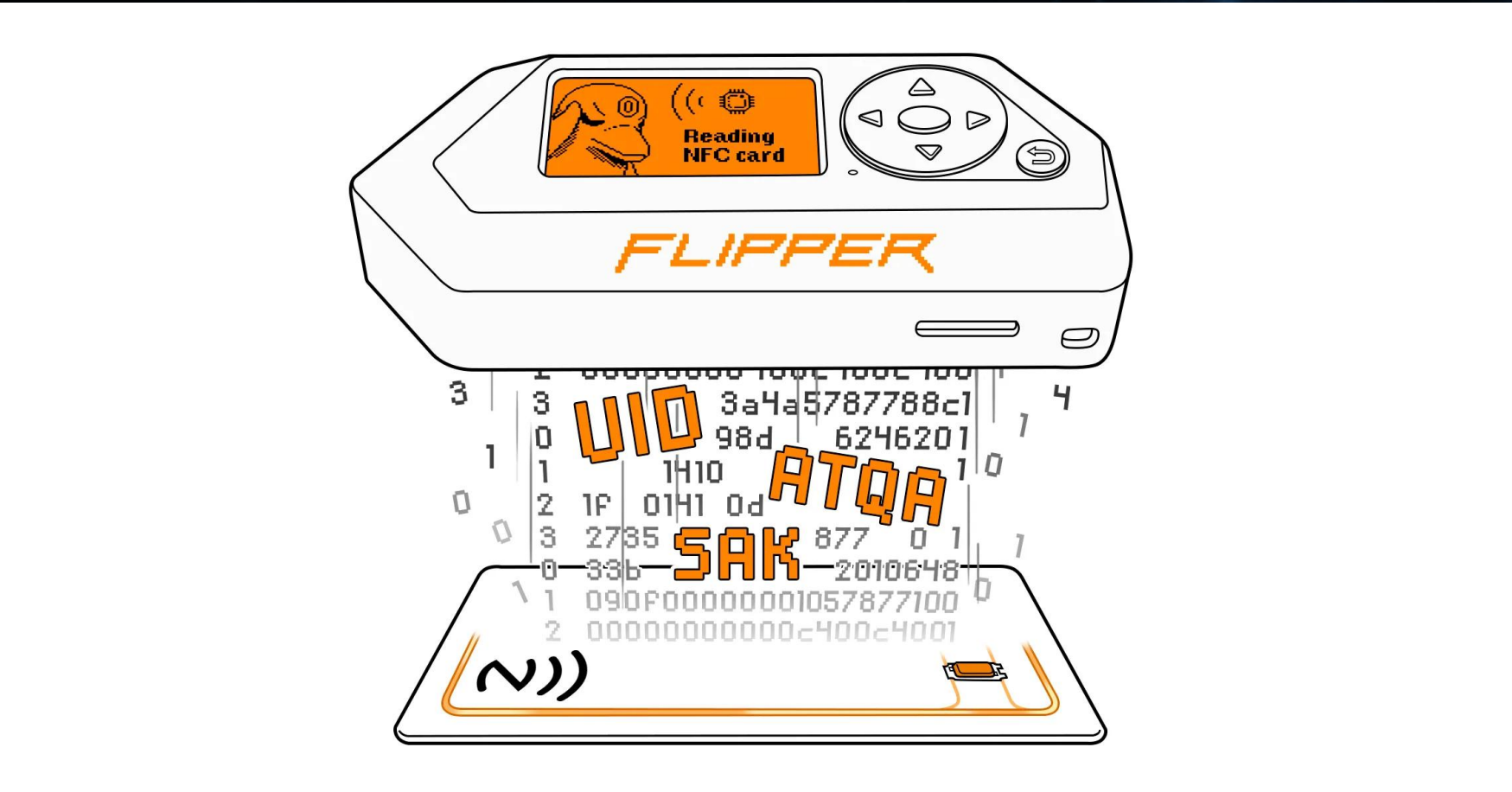
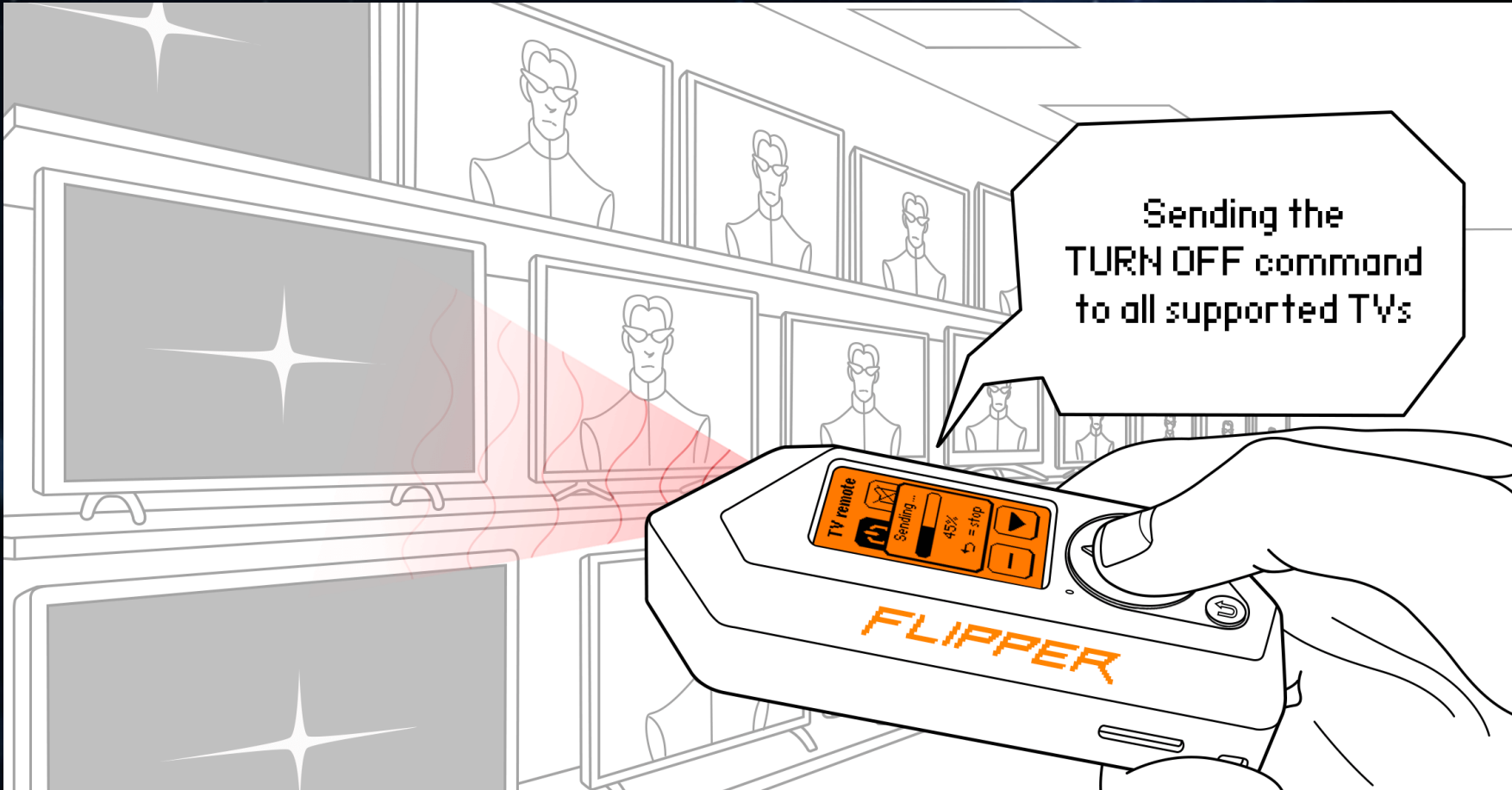
Flipper Zero的其它功能

Flipper Zero的非Sub-Ghz功能:

- M1卡克隆与嗅探、ID卡克隆与爆破
- 红外遥控克隆/分析/爆破
- 蓝牙相关漏洞利用、iButton克隆与爆破
- BadUSB与USB存储



Flipper Zero官方文档



更高级的无线攻防 – HackRF

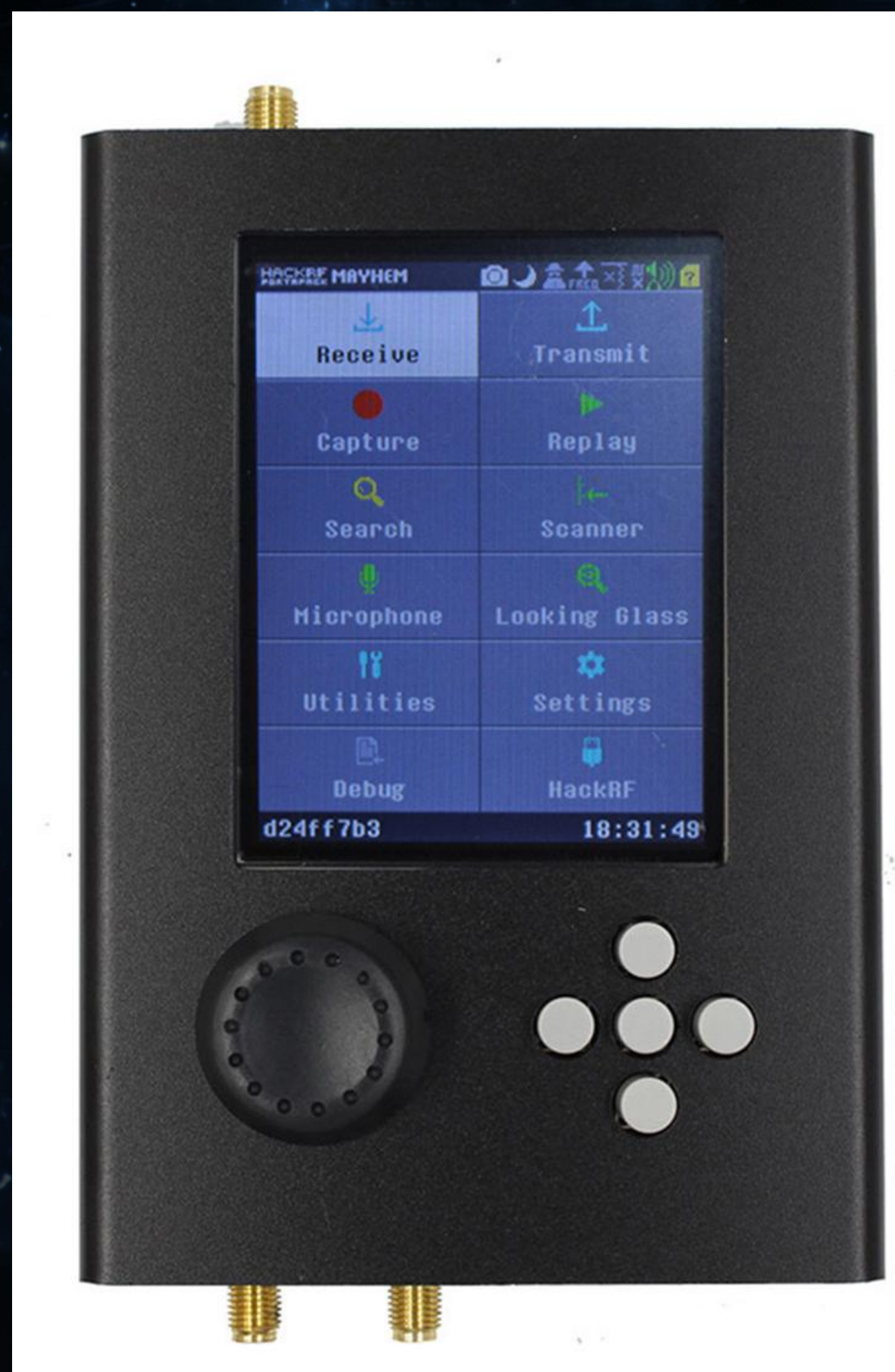
专业的无线安全研究工具

向下兼容Fillper Zero的所有Sub-Ghz
功能

除此之外，支持接收和发射：

广播、飞机\船舶跟踪(AIS)、汽车胎压监测、寻呼机、蓝牙、对讲机等。

GPS伪造、信号干扰、伪基站



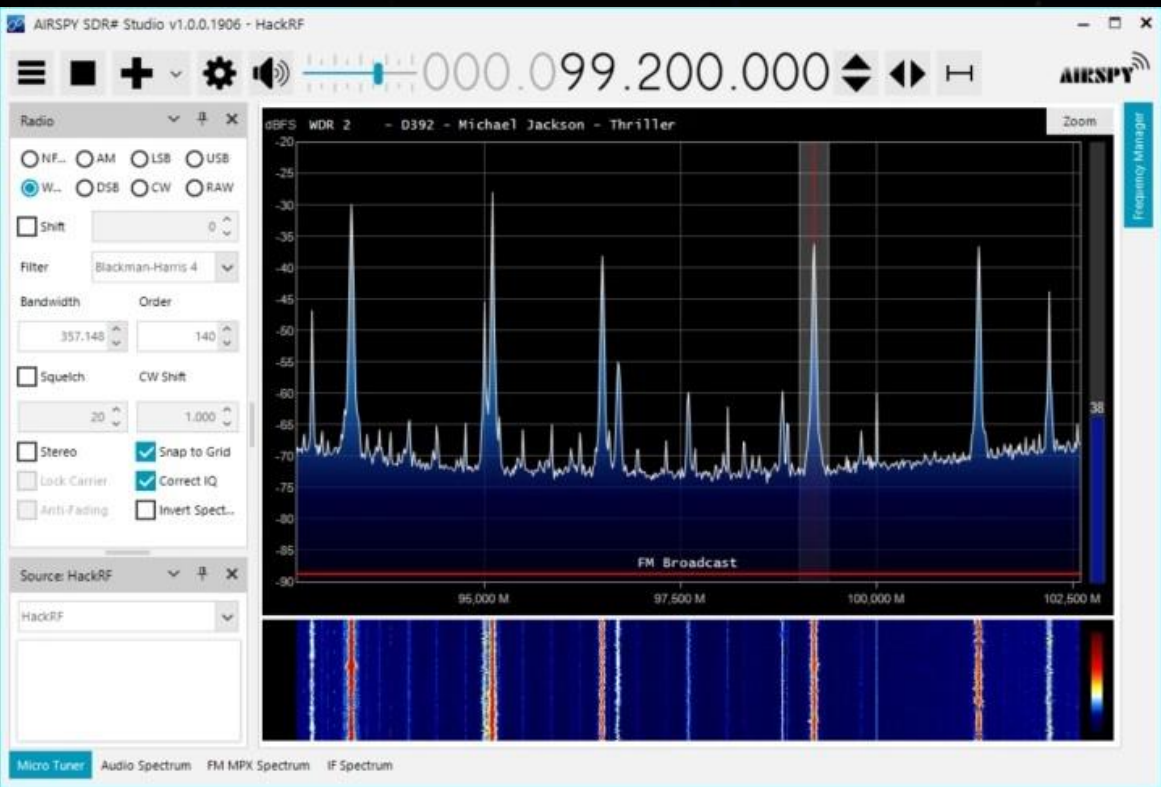
更高级的无线攻防 – HackRF



云鼎实验室

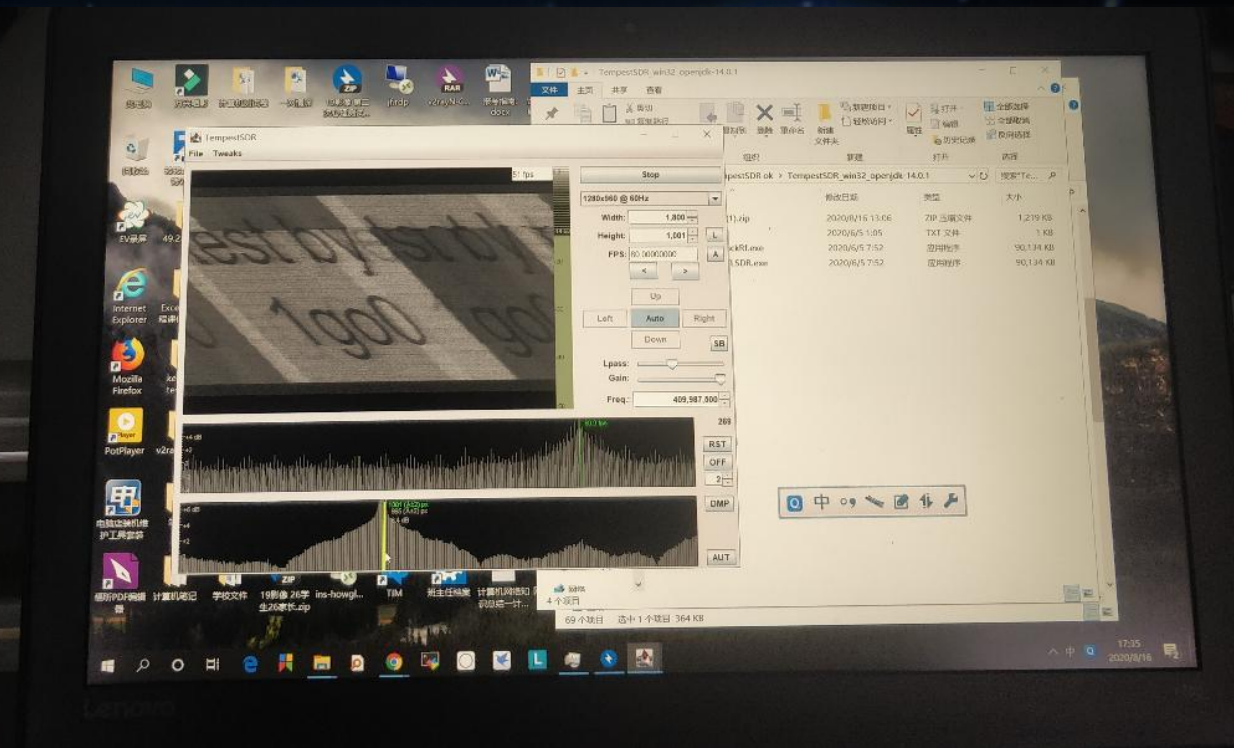


腾讯云安全



Wireshark 1.12.7 (Git Rev Unknown from unknown) interface. The main window displays a list of captured packets. The selected packet is a GSM SMS message. The packet details pane shows the structure of the SMS message, including the TP-DCS, TP-Service-Centre-Time-Stamp, and TP-User-Data fields.

No.	Time	Source	Destination	Protocol	Length	Info
204	14.045302000	127.0.0.1	127.0.0.1	LAPDM	81	U, func=Unknown(OTAP) (SS)
205	14.063132000	127.0.0.1	127.0.0.1	LAPDM	81	I, N(R)=0, N(S)=1 (Fragment)
206	14.096241000	127.0.0.1	127.0.0.1	LAPDM	81	U, func=UUT(OTAP) (RR) System Information Type 5bis
207	14.158617000	127.0.0.1	127.0.0.1	LAPDM	81	U, func=Unknown(OTAP) (SS)
208	14.176256000	127.0.0.1	127.0.0.1	LAPDM	81	I, N(R)=0, N(S)=2 (Fragment)
209	14.274194000	127.0.0.1	127.0.0.1	LAPDM	81	U, func=Unknown(OTAP) (SS)
210	14.292620000	127.0.0.1	127.0.0.1	GSM SMS	81	I, N(R)=0, N(S)=3(OTAP) (SMS) CP-DATA (RP) RP-DATA (Network to MS)
211	14.325017000	127.0.0.1	127.0.0.1	LAPDM	81	U, func=UUT(OTAP) (RR) System Information Type 5ter
212	14.366901000	127.0.0.1	127.0.0.1	LAPDM	81	U, func=Unknown(OTAP) (SS)
213	14.407120000	127.0.0.1	127.0.0.1	LAPDM	81	S, func=RR, N(R)=1
214	14.511850000	127.0.0.1	127.0.0.1	LAPDM	81	U, func=Unknown(OTAP) (SS)
215	14.530518000	127.0.0.1	127.0.0.1	LAPDM	81	U, func=UUT(OTAP) (RR) System Information Type 6
216	14.570963000	127.0.0.1	127.0.0.1	LAPDM	81	U, func=UUT(OTAP) (RR) System Information Type 6



HACKRF MAYHEM

Receive

Transmit

Transceiver

Recon

Capture

Replay

Remote

Looking Glass

Utilities

Games

Settings

HackRF

n_260314 2026-03-22 19:16:18



BLE RX interface. The main window displays a list of captured MAC addresses and their corresponding hits. The list is sorted by MAC address. The interface includes various controls for filtering and displaying the data.

Mac Address	Hits	dB
5A:FB:73:00:71:B8	16	-22
61:66:2C:22:B3:62	6	-21
65:4E:DF:8F:5C:13	2	-24
68:BB:DE:61:E4:8C	7	-13
6B:ED:C2:CA:92:8D	1	-22
71:E7:E2:19:31:E5	1	-16
DC:27:3F:55:0B:D9	2	-26



KeeLoqTX

Manufacturer: Rossi

Serial: 00677063

Fix: 20677063

Hop: 2063027D

Counter: 637

Button: 2

Repeat: 4

Payload:

D0B72A53C60EE604

Open file

Ready

433.9200 50kHz 9kHz

Gain:35 Amp: 0

START

抱着HackRF在渗透测试现场的我

云鼎实验室 | 腾讯云安全



无线安全常用设备

	国产无线电锁重放器	Flipper Zero	HackRF One + PortaPack
用途	无线电锁重放	安全测试工具	软件定义无线电(SDR)
频率范围	仅315MHz、433MHz	Sub-GHz (300-928 MHz)	1MHz - 6GHz
常用功能	重放无线电门禁信号 干扰无线电门禁信号	Sub-GHz: 重放、爆破无线遥控器 RFID+NFC: 克隆IC卡与ID卡、mfkey32攻击等 红外: 重放、爆破红外遥控器 USB: BadUSB、储存设备 iButton: 接触式钥匙	接收、分析、发射射几乎所有主流无线电信号。
操作模式	手持	手持 / 手机APP远程控制	手持 / 连接电脑
优点	廉价 无需跳频 较好适配国内常见协议	支持除无线电外的其它功能 软件生态完善，上手难度低 便携、支持远程控制	几乎无上限的无线电功能
缺点	支持的协议有限 信号较差	非完整SDR设备，无线有部分限制	入门难度高 不便携
价格	70元	600元(国产版) / 1700元(原版)	1100元

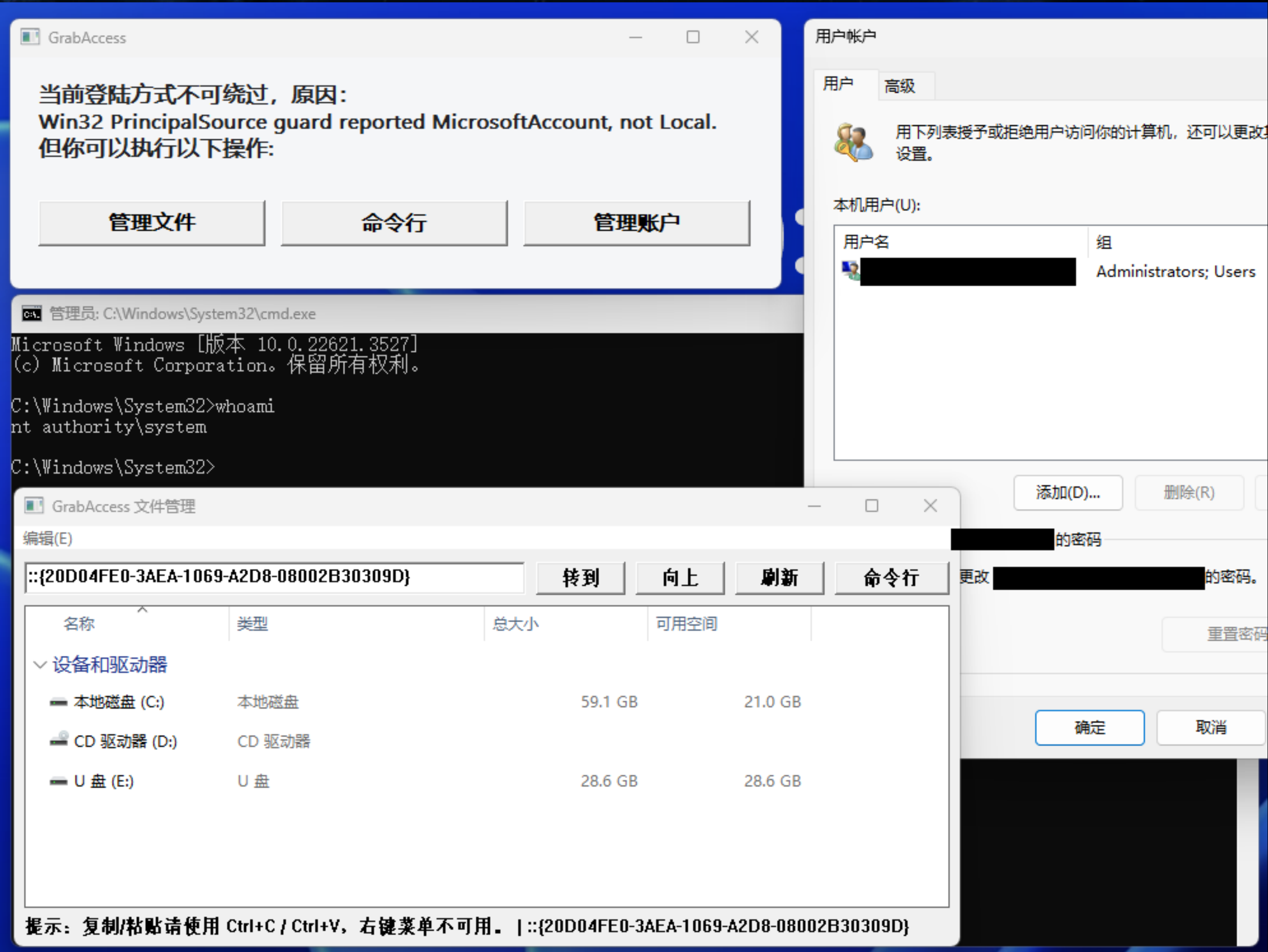
在现实世界接近或接触被测对象的安全测试



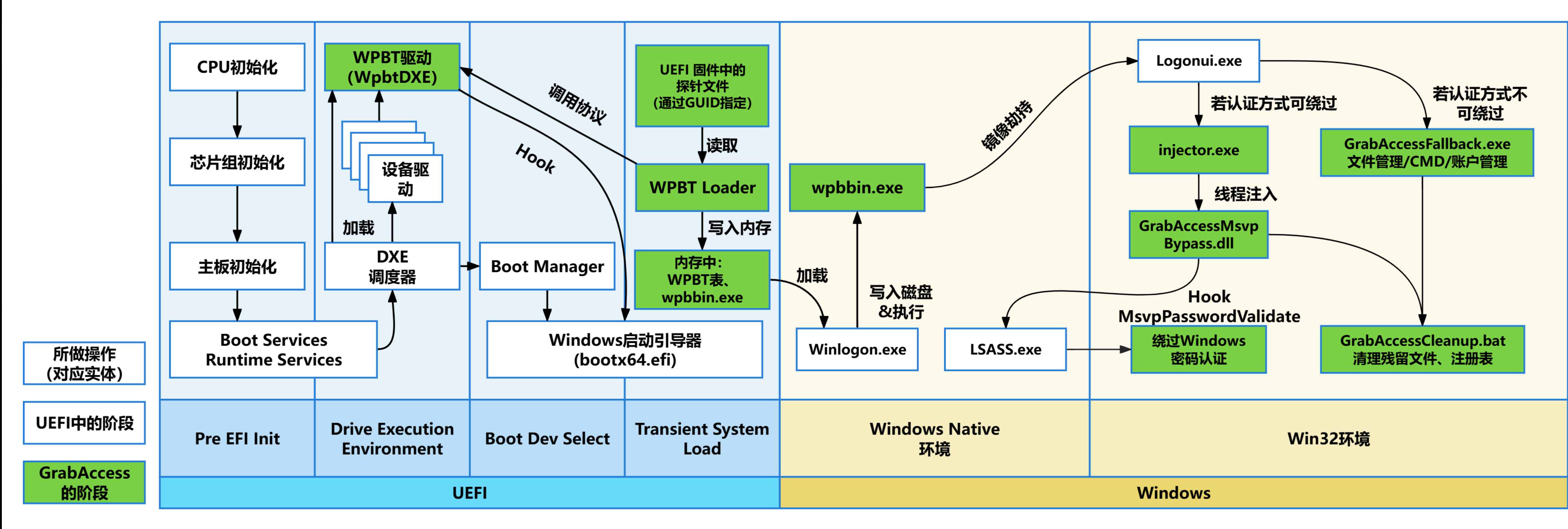
GrabAccess – 物理接触时绕过Windows登陆密码

从安装有GrabAccess
的U盘引导后:

- 1. 绕过本地登录校验
- 2. 以System权限管
理文件或账户



GrabAccess利用了Windows的一项合法后门: WPBT (Windows Platform Binary Table) 。



GrabAccess – 物理接触时植入主板UEFI Bootkit

通过修改主板UEFI固件实现终极持久化 (Bootkit) :

- 每次Windows系统启动时, GrabAccess会写入指定的程序
- 无视重装系统或更换硬盘
- 只能通过刷写主板固件或更换主板移除

简要操作流程:

1. 将GrabAccess与要植入的程序打包
2. 提取主板UEFI固件 (软件读取 / 官网固件包)
3. 向UEFI固件插入GrabAccessDXE
4. 将固件刷回主板 (建议使用CH341A编程器)



UEFI BIOS的读取与刷写

云鼎实验室 | 腾讯云安全



来自2015年的旧闻：

“新京报讯 [记者刘洋] 在给水货手机重新安装操作系统时，偷装插件并借此远程操控客户手机，偷偷掌控了40万手机用户信息，窃取通讯录近2000万条。

安丰公司的主要业务是开发APP STORE业务，类似于“软件商店”，供安卓系统用户下载APP；万丰公司主要为水货手机“刷机”，提供操作系统包，麦德联合系推广公司。很多销售水货智能手机的客户会找他们“刷机”，即把水货在深圳解锁、重装中文版操作系统再销售。

生意最好时，深圳的公司一天能刷机上万部，但他们并不满足，杨小慧说，2011年底开始，他和陈新、罗真运、张炳开发了类似于木马的插件——“静默插件”，趁刷机时偷装在手机里，这插件像病毒一样偷偷控制着客户手机。

案发后，北京通达首城司法鉴定所鉴定确认，“静默插件”有在用户不知情的情况下，获取手机位置、网络状态、用户手机运行的应用软件列表的功能。根据鉴定结果，这一“流氓插件”还能更改用户网络状态，读写用户存储卡及GPS定位。他们非法获取手机通讯录近2000万条。”

硬件供应链污染的历史 – 1970s

- 1976年至1984年间，苏联在美国大使馆的16台打字机中安装了键盘记录器
- 最早有记录的硬件供应链攻击
- 可能是在运输途中经过海关时被KGB拦截和植入
- 使用无线电回传数据到附近的接收站
- NSA启动了GUNMAN计划，从大使馆中秘密撤出了11吨设备进行安全分析
- 2012年NSA解密了GUNMAN计划的相关文件



参考来源:

- 1、 <https://www.cryptomuseum.com/covert/bugs/selectric/index.htm>
- 2、 *Learning from the enemy: the GUNMAN project[M]. Center for Cryptologic History, NSA, 2012.*



硬件供应链污染的历史 – 2000s

- 2013年 *NSA ANT Catalog* 泄漏:
包含一系列物理接触下使用的黑客工具。
- 2014年 *No Place to Hide* 出版:
揭露NSA在物流网络中拦截设备并植入后门。

(TS//SI//NF) Such operations involving **supply-chain interdiction** are some of the most productive operations in TAO, because they pre-position access points into hard target networks around the world.



(TS//SI//NF) Left: Intercepted packages are opened carefully; Right: A “load station” implants a beacon



TOP SECRET//COMINT//REL TO USA, FVEY

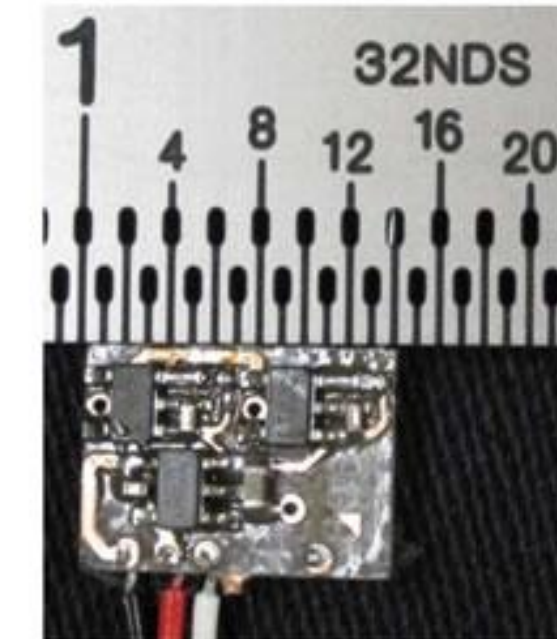
SURLYSPAWN ANT Product Data

(TS//SI//REL TO USA,FVEY) Data RF retro-reflector. Provides return modulated with target data (keyboard, low data rate digital device) when illuminated with radar.

07 Apr 2009

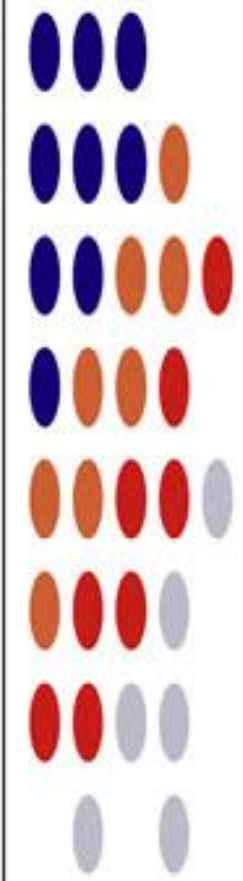
(U) Capabilities

(TS//SI//REL TO USA,FVEY) SURLYSPAWN has the capability to gather keystrokes without requiring any software running on the targeted system. It also only requires that the targeted system be touched once. The retro-reflector is compatible with both USB and PS/2 keyboards. The simplicity of the design allows the form factor to be tailored for specific operational requirements. Future capabilities will include laptop keyboards.



(U) Concept of Operation

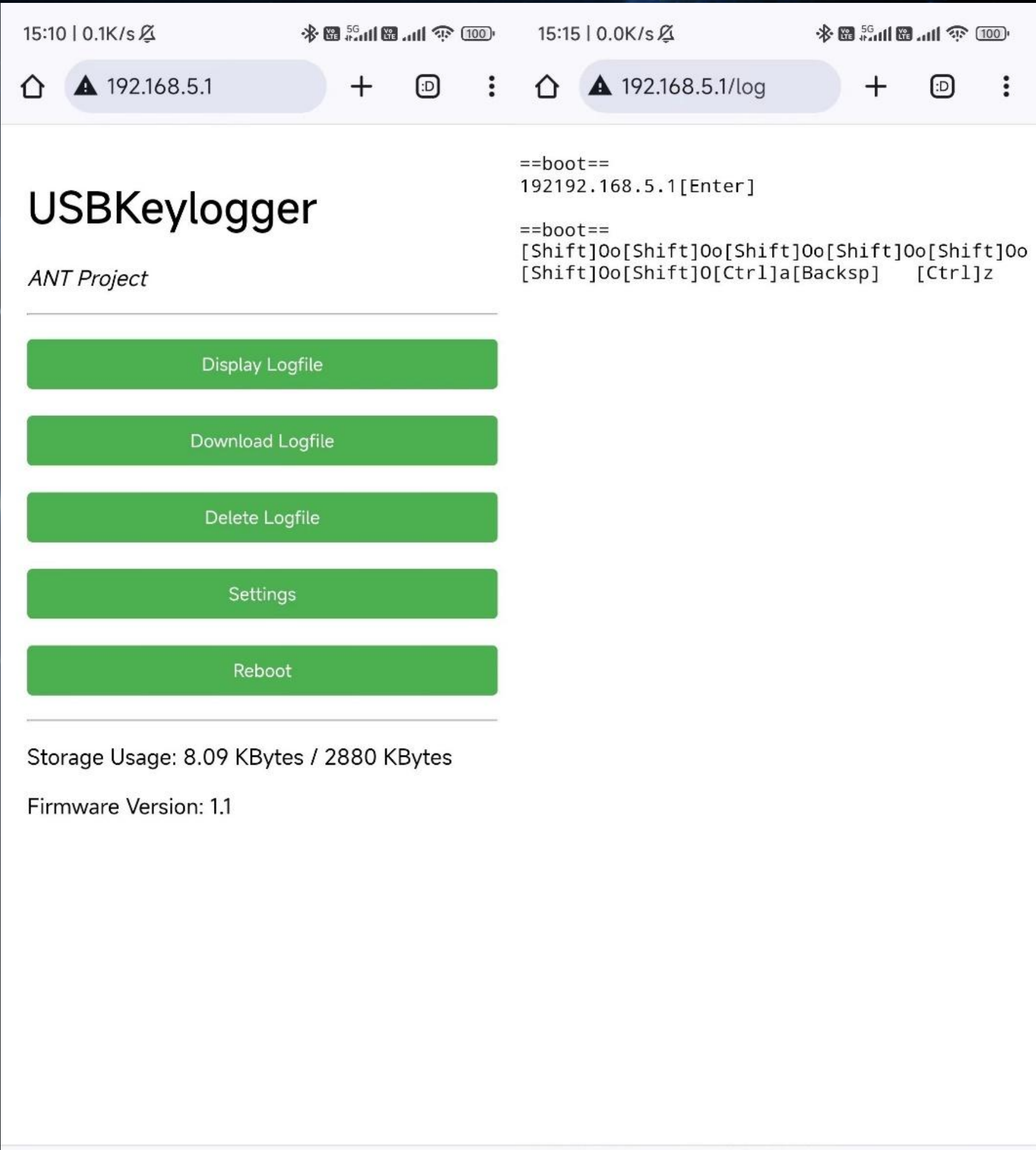
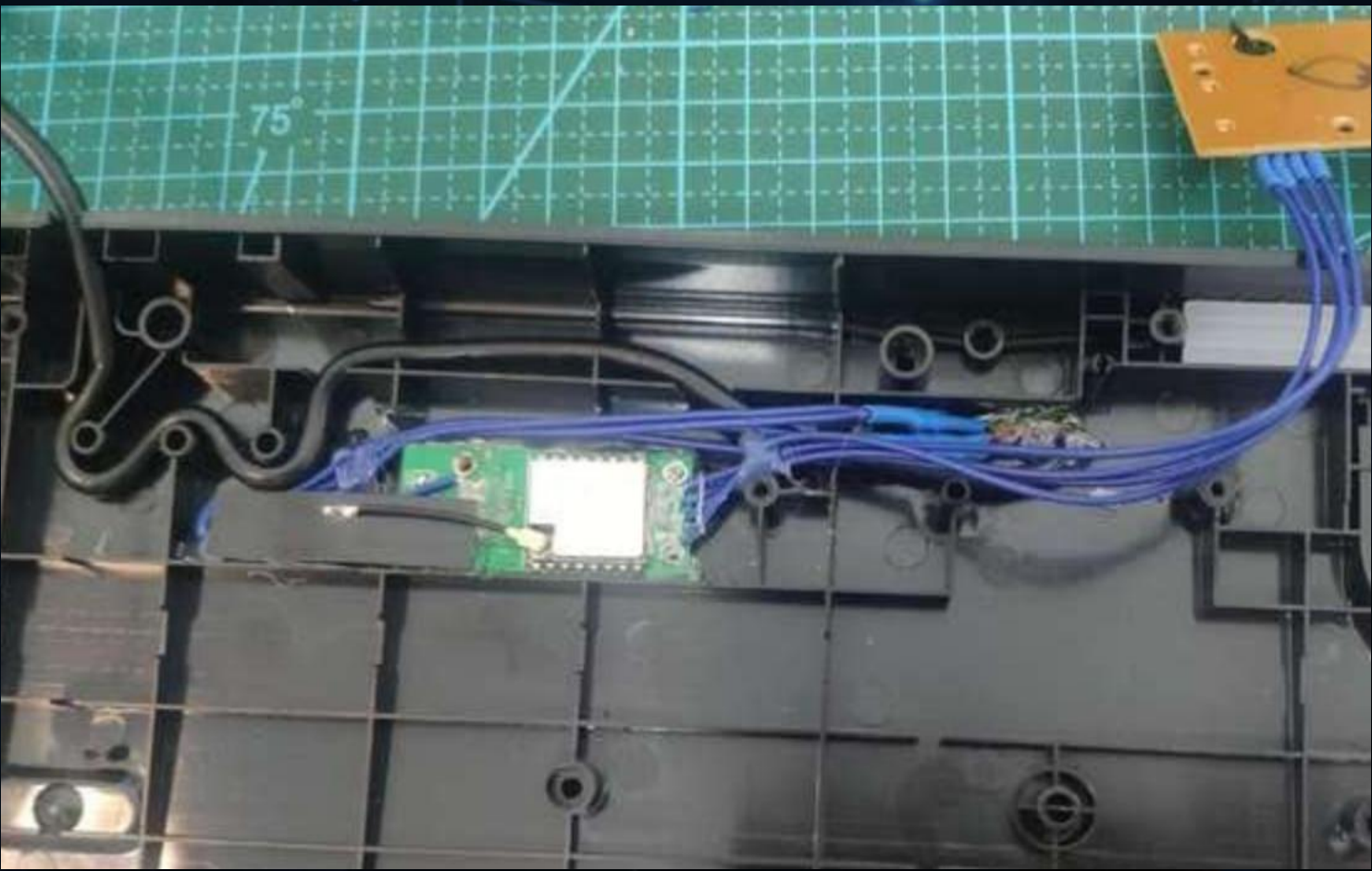
(TS//SI//REL TO USA,FVEY) The board taps into the data line from the keyboard to the processor. The board generates a square wave oscillating at a preset frequency. The data-line signal is used to shift the square wave frequency higher or lower, depending on the level of the data-line signal. The square wave, in essence, becomes frequency shift keyed (FSK). When the unit is illuminated by a CW signal from a nearby radar, the illuminating signal is amplitude-modulated (AM) with this square wave. The signal is re-radiated, where it is received by the radar, demodulated, and the demodulated signal is processed to recover the keystrokes. SURLYSPAWN is part of the ANGRYNEIGHBOR family of radar retro-reflectors.



USBKeylogger —— 硬件键盘记录器

硬件键盘记录器:

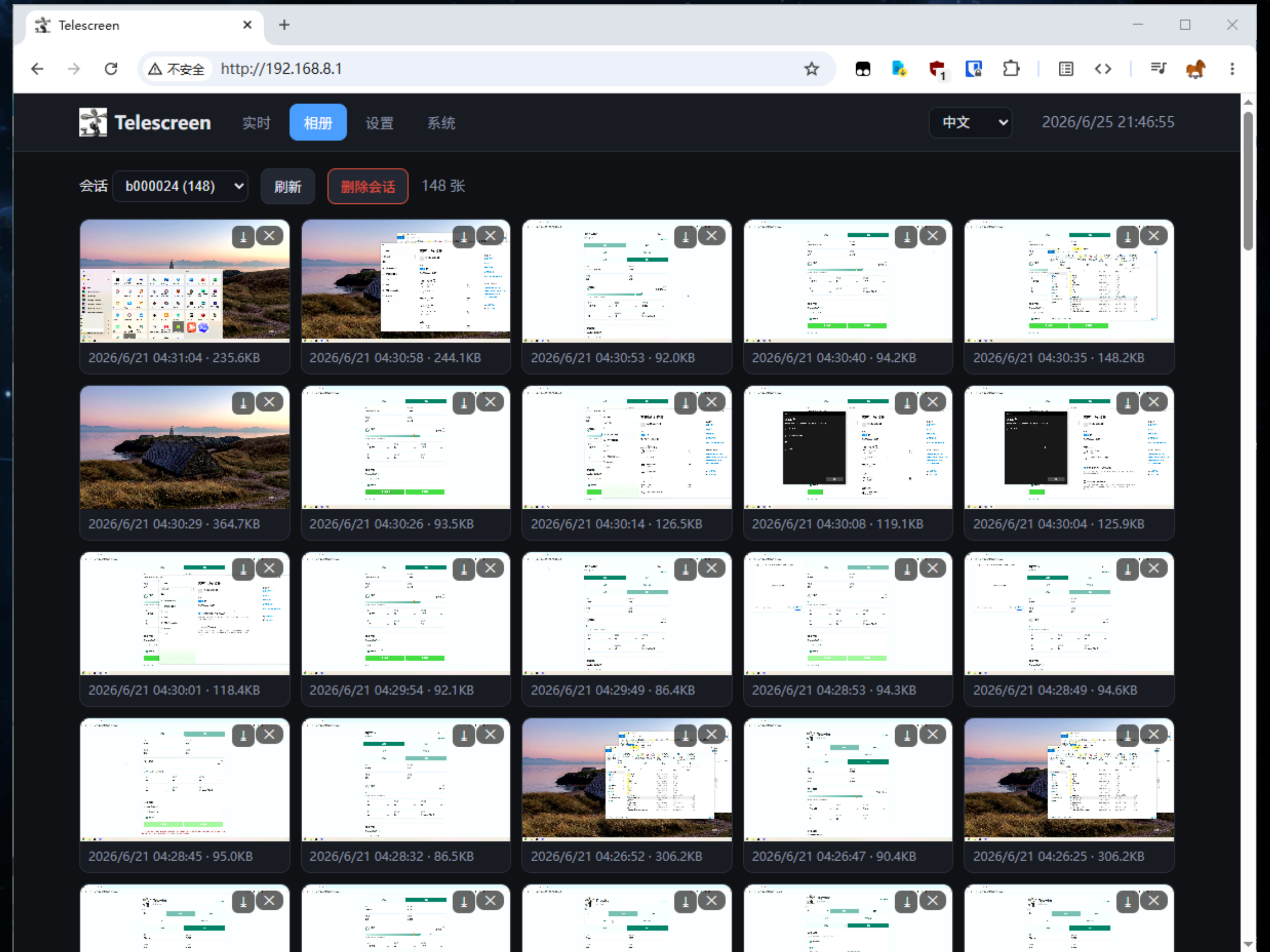
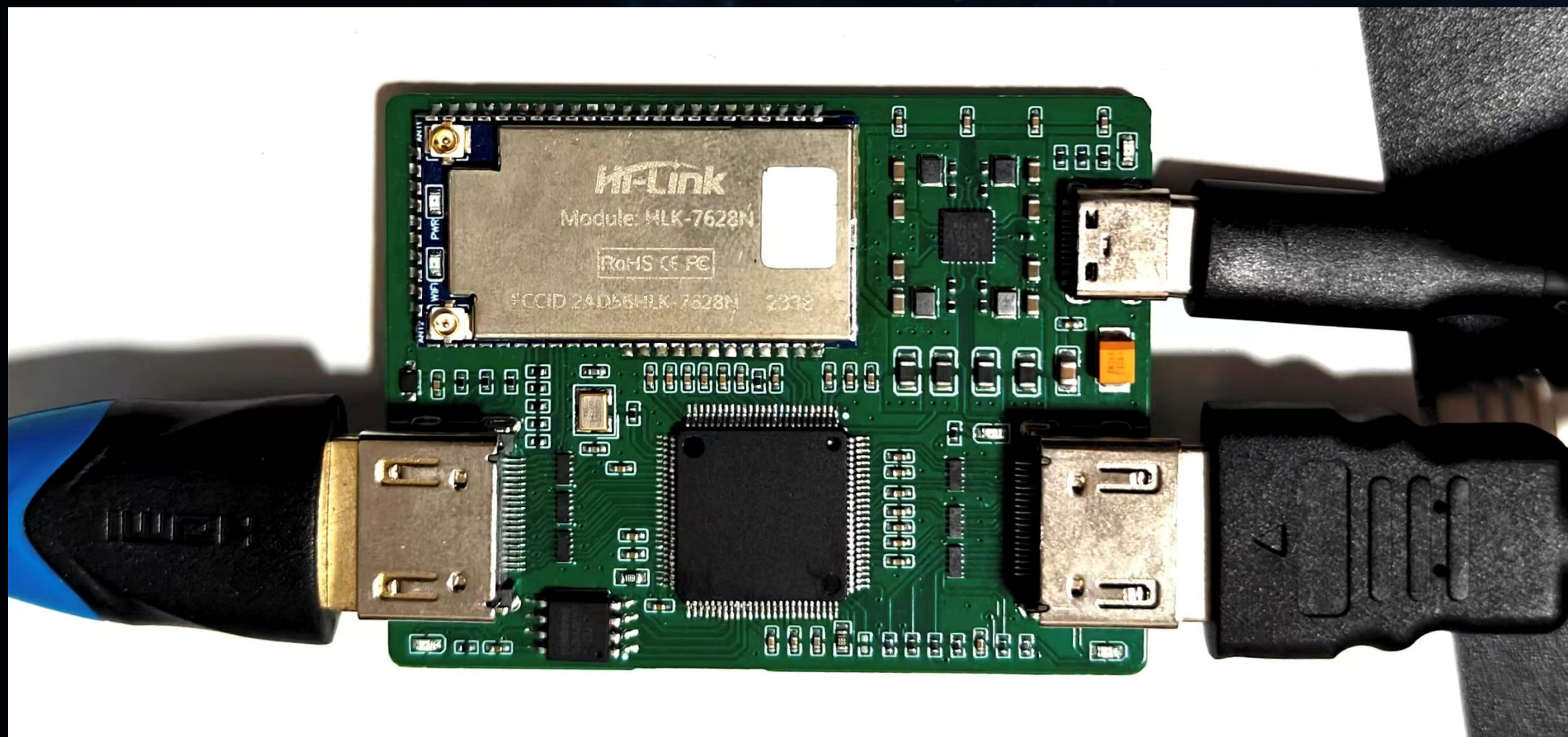
- 安装在 USB 接口和键盘之间，记录键盘输入
- 两款硬件规格，适配不同植入场景
- 带 Wi-Fi 功能，可远程访问
- 记录内容自动回传



Telescreen —— 硬件屏幕记录器

Telescreen 安装在 HDMI 接口和屏幕之间，可以：

- 定时抓取屏幕内容，并保存到 MicroSD 卡
- 开启屏幕串流，远程监控屏幕内容
- 空白画面过滤和近似重复帧去重
- 带 Wi-Fi 功能，可远程访问



近源场景下的计算机渗透 —— DMA

利用支持直接内存访问 (*Direct Memory Access, DMA*) 的设备攻击计算机

常见用途:

- 绕过计算机安全措施[绕过登陆密码、失效UEFI可信链]
- 读写任意进程的内存[植入ShellCode、数字取证、游戏外挂]



火线接口



USB4接口



M.2接口

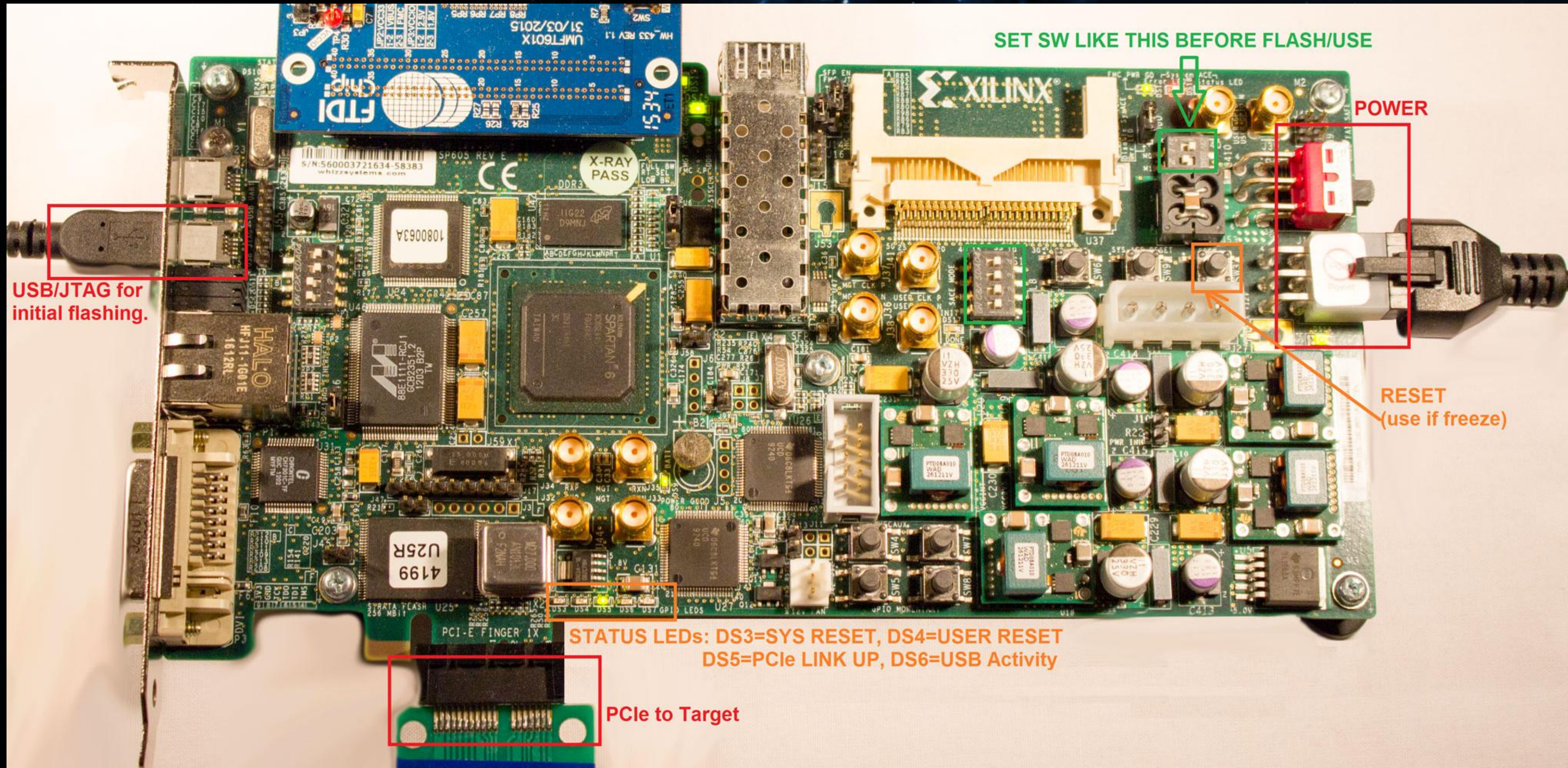


PCIe接口

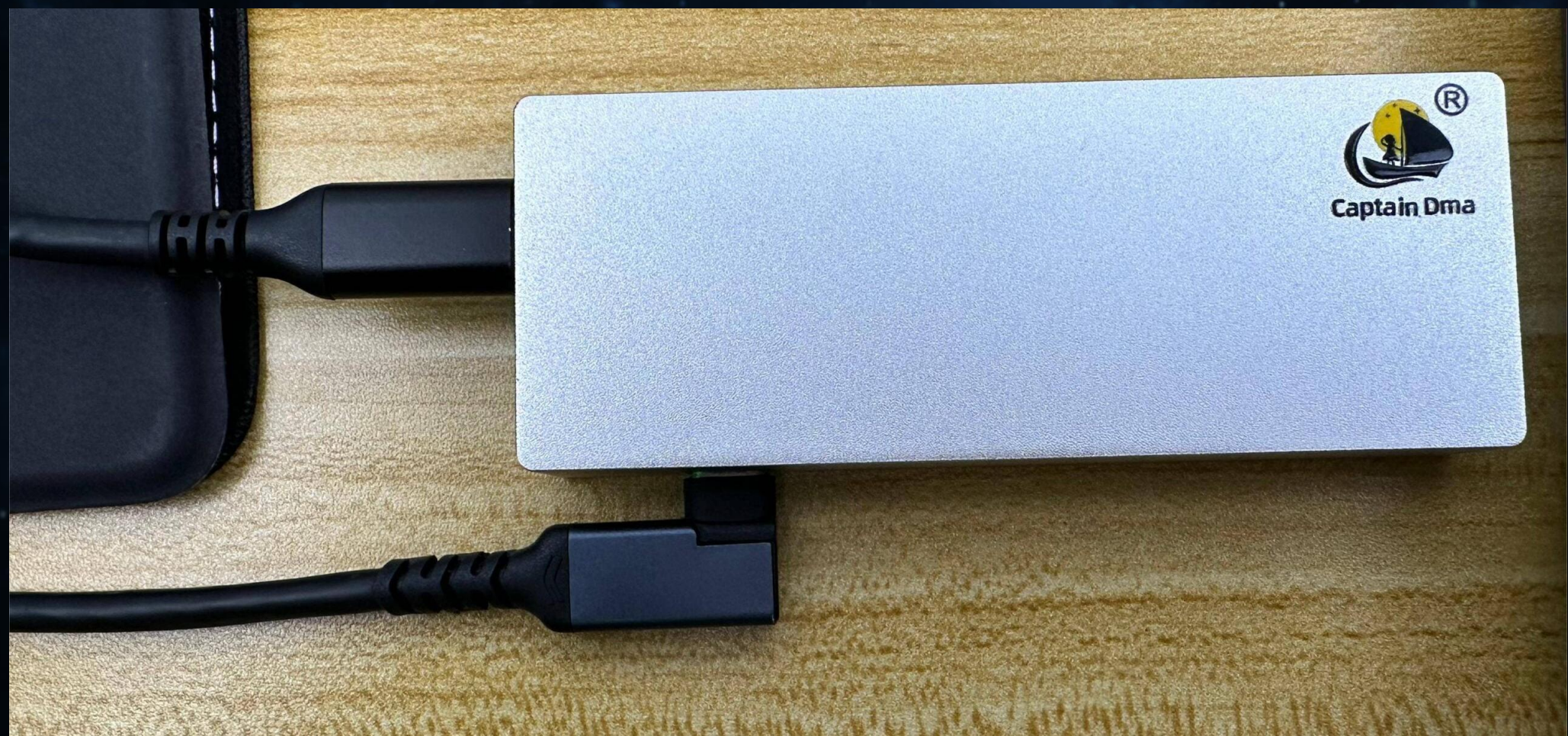
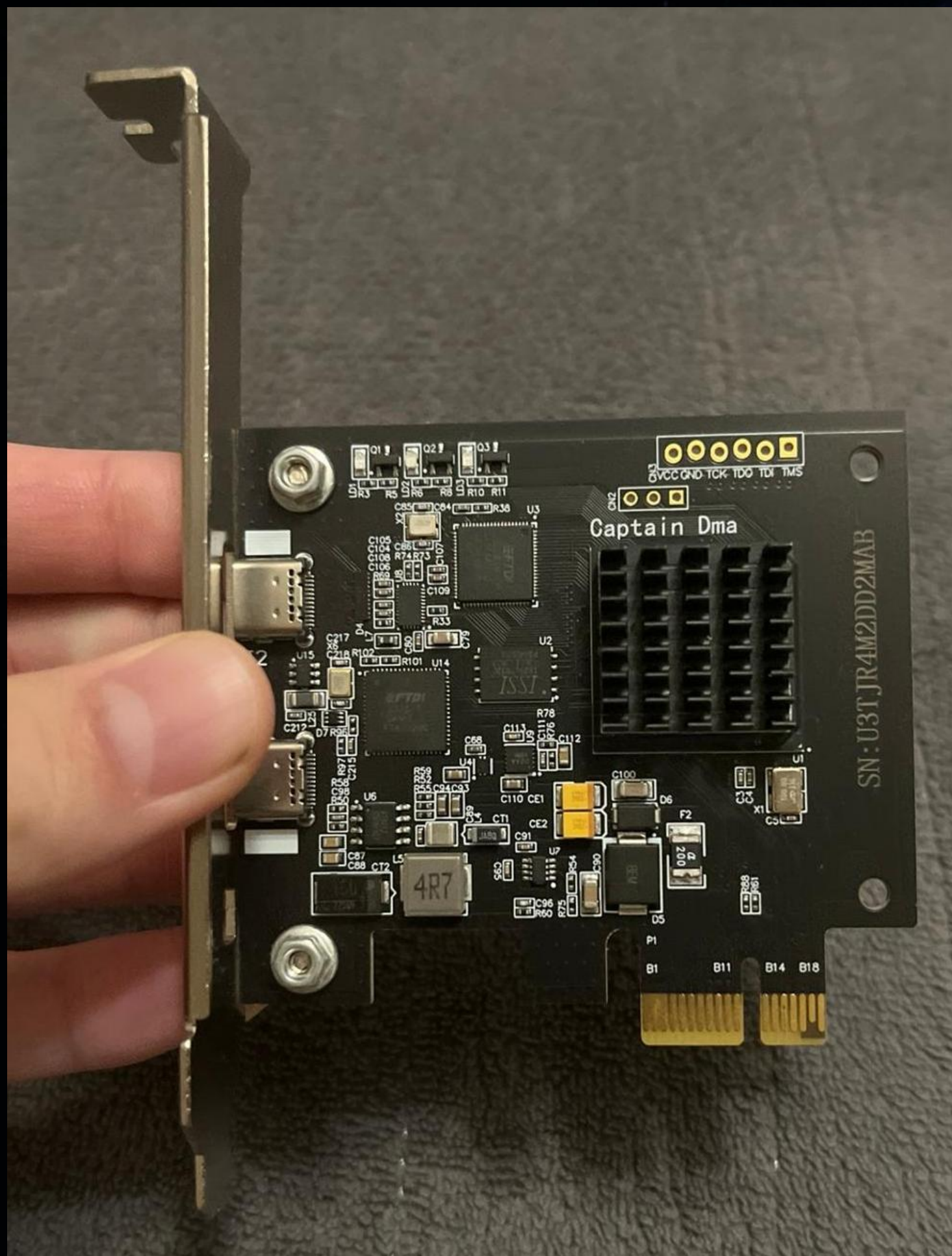
DMA攻击的历史

时间	类型	事件
2004年	攻击技术	柏林混沌通讯大会，使用iPod DMA攻击计算机，可能是最早的DMA攻击实例。
2004-2010年	攻击技术	DMA(主要基于FireWire)被广泛用于数字取证。
2009年	缓解措施	首批支持硬件IOMMU(VT-d)的处理器(Intel Xeon E5500)发布。
2014年	攻击手段	inception项目发布，使用FireWire、Thunderbolt等接口绕过登陆密码。
2014年	缓解措施	Mac OSX 10.7.2和Windows 8.1禁用锁屏下的FireWire DMA。
2016年	缓解措施	Mac OSX 10.12.2版本为所有支持VT-d的计算机开启DMA保护。
2016年	攻击手段	DEFCON 24，PCILeech发布，后续成为最完善的DMA攻击平台。
2017年	攻击手段	地下论坛出现基于DMA的游戏外挂，DMA攻防的主场转向游戏作弊。
2017年	缓解措施	UEFI参考代码支持DMA防御措施。
2018年	缓解措施	Windows 10 1803支持基于IOMMU的内核DMA保护。
2018年	攻击手段	pcileech-webradar发布，可能是第一个开源的，基于DMA的CS:GO雷达外挂。
2021-2023年	缓解措施	BattlEye、Vanguard等反作弊软件开始对抗DMA外挂，主要手段为检测DMA设备VID、PID、处理特殊PCIE数据包时的特征。
2023年	攻击手段	Ekknod发布pcileech-wifi，将DMA设备伪装成网卡，避免反外挂检测，后成为DMA外挂逃避检测的主要手段。
2024年至今	缓解措施	大量游戏强制要求开启IOMMU和SecureBoot，避免DMA攻击。

DMA攻击的设备



DMA攻击的设备



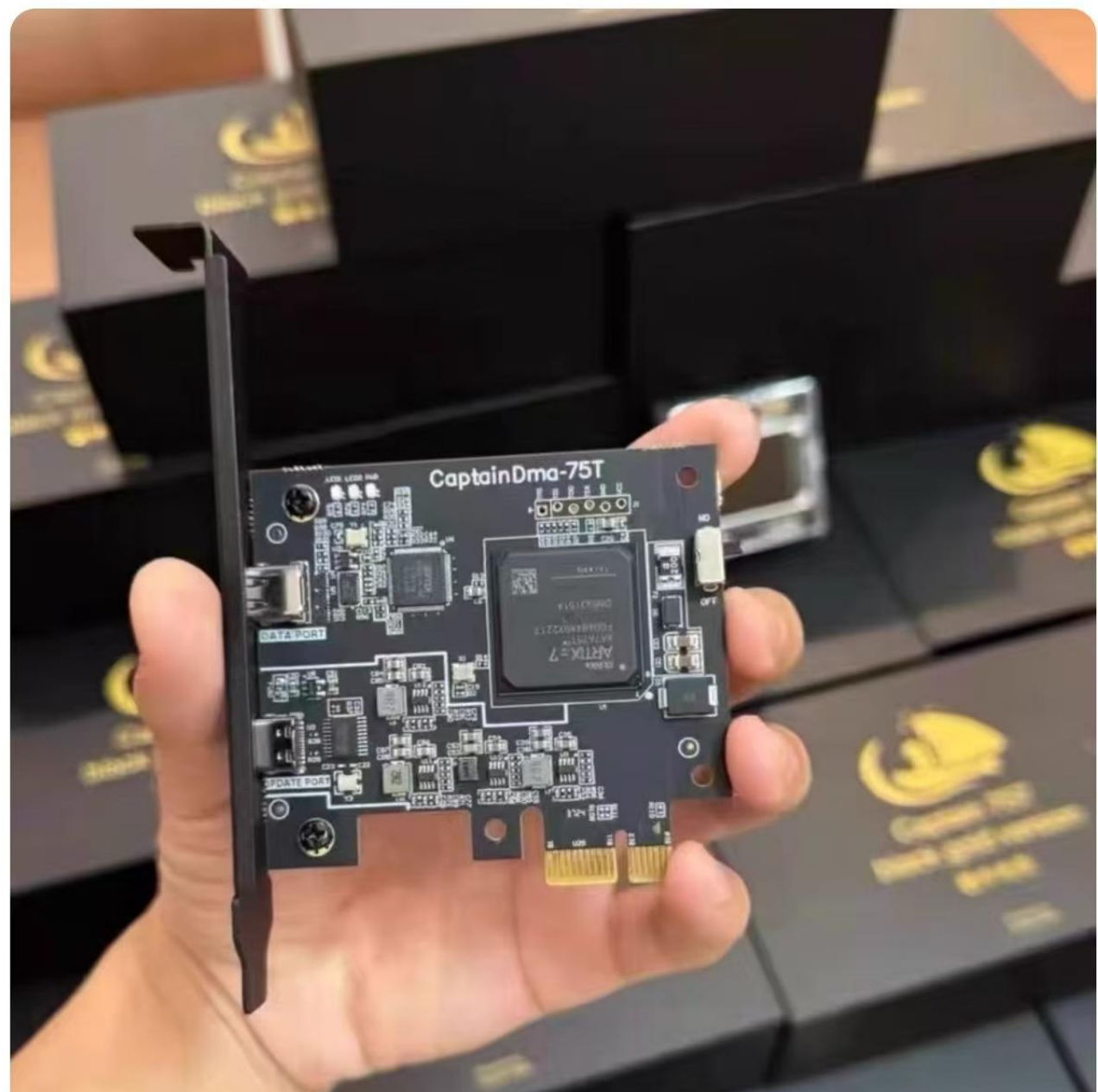
云鼎实验室 | 腾讯云安全

¥280-305 活动价

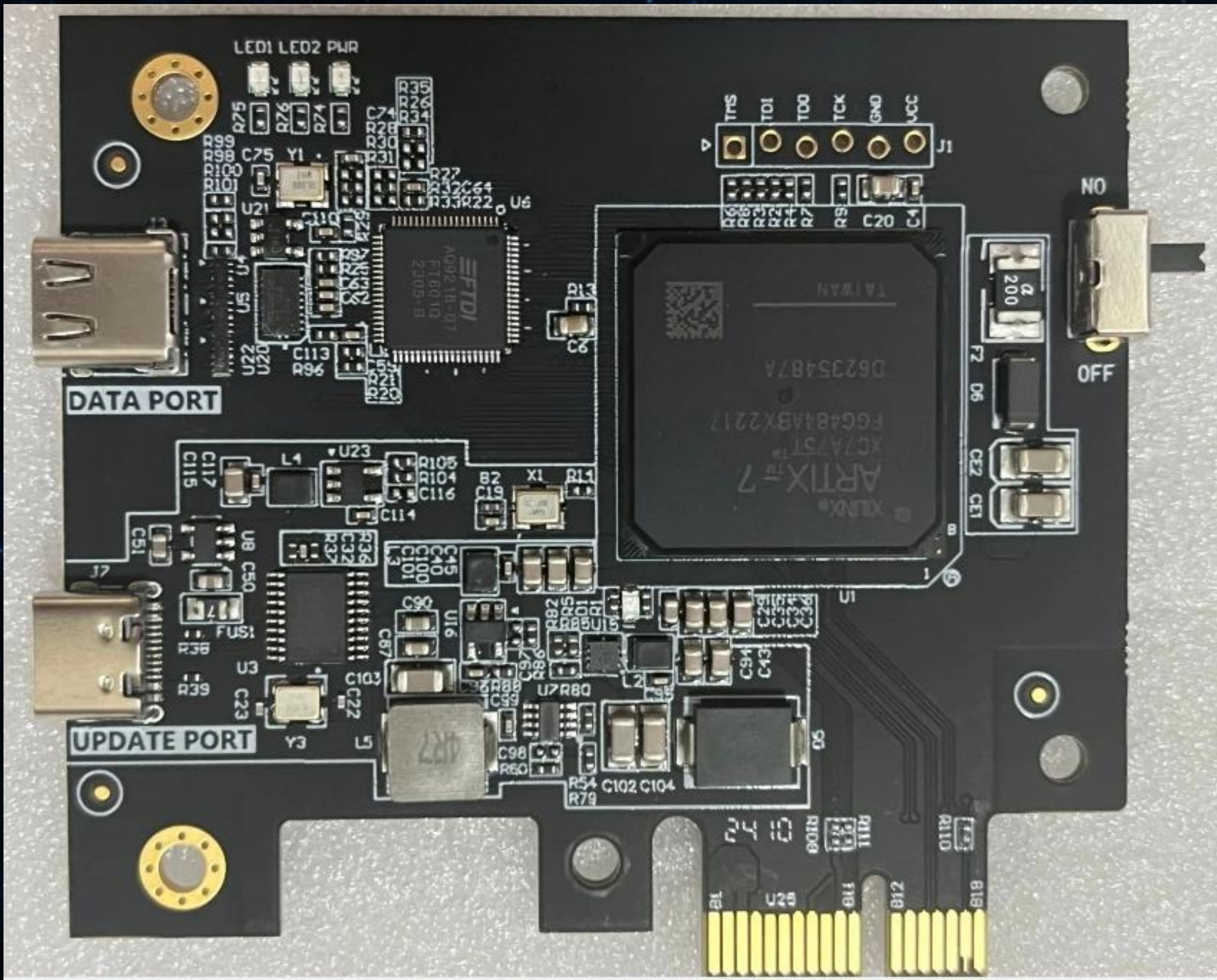
包邮 1080人想要 | 1.9万人浏览

全新DMA Cap75t开发版，厂家直发。新板子自带基础测速固件，附带线缆、固定支架、散热片。

支持烧录固件测速，USB3.0与Typ-c接口齐全。



基于PCILeech的DMA攻击



基于PCILeech的DMA攻击

PCILeech与MemProcFS

动态分析内存并
映射成文件系统



← → ∨ ↑ 此电脑 > M (\\MemProcFS) (M:) >					在 M (\\Men	
快速访问		名称 ^	修改日期	类型	大小	
桌面		conf	2026/7/1 10:46	文件夹	MemProcFS 配置	
下载		forensic	2026/7/1 10:46	文件夹	取证插件运行结果	
文档		misc	2026/7/1 10:46	文件夹	杂项插件运行结果	
图片		name	2026/7/1 10:46	文件夹	按照进程名查看进程内存	
此电脑		pid	2026/7/1 10:46	文件夹	按照PID查看进程内存	
视频		py	2026/7/1 10:46	文件夹		
		registry	2026/7/1 10:46	文件夹	注册表内容	
		sys	2026/7/1 10:46	文件夹	系统信息，进程表、网络连接、服务、驱动等	
此电脑		LICENSE.txt	2026/7/1 10:46	文本文档	34 KB	
> 系统 (C:)		memory.dmp	2026/7/1 10:46	DMP 文件	34,590,21...	完整内存镜像
> 新加卷 (D:)		memory.pmem	2026/7/1 10:46	PMEM 文件	34,590,20...	
> U 盘 (E:)						
> M (\\MemProcFS) (M:)						

基于PCILeech的DMA攻击

- 通过文件查看进程、模块、注册表、驱动、网络连接等信息
- 包含一系列分析、取证插件

快速访问

桌面

下载

文档

图片

此电脑

视频

此电脑

系统 (C:)

新加卷 (D:)

U 盘 (E:)

M (\\MemProcFS) (M:)

此电脑 > M (\\MemProcFS) (M:) > misc > bitlocker

名称

修改日期

类型

大小

ffffac859eca9010.bin

2026/7/1 10:46

BIN 文件

2 KB

ffffac859eca9010.fvek

2026/7/1 10:46

FVEK 文件

1 KB

ffffac859eca9010.txt

2026/7/1 10:46

文本文档

1 KB

readme.txt

2026/7/1 10:46

文本文档

2 KB

ffffac859eca9010.txt - 记事本

文件(F) 编辑(E) 格式(O) 查看(V) 帮助(H)

Address: 0xffffac859eca9010

Cipher: AES-XTS 128-bit

Key: 011c206b2d76

M (\\MemProcFS) (M:) > name >	
名称	修改日期
Codex.exe-15620	2026/7/1 10:49
Codex.exe-15920	2026/7/1 10:49
Codex.exe-17168	2026/7/1 10:49
conhost.exe-6932	2026/7/1 7:15
conhost.exe-14716	2026/7/1 10:49
conhost.exe-14828	2026/7/1 10:32
conhost.exe-16500	2026/7/1 10:43
cowork-svc.exe-7796	2026/7/1 7:15
csrss.exe-704	2026/7/1 7:15
csrss.exe-816	2026/7/1 7:15
csrss.exe-6400	2026/7/1 10:31
ctfmon.exe-7484	2026/7/1 10:31
CxAudioSvc.exe-7156	2026/7/1 7:15
dasHost.exe-4916	2026/7/1 7:15
DiagsCap.exe-4580	2026/7/1 7:15
dllhost.exe-8092	2026/7/1 10:49
dllhost.exe-12108	2026/7/1 7:15
dllhost.exe-14072	2026/7/1 10:39

基于PCILeech的DMA攻击

使用PCILeech加载KMD，进行高级操作

PushPin集成了PCILeech常用的操作



第一步：
加载OS对应的内核模块

- 1、Patch登录密码
- 2、SYS或用户权限的CMD
- 3、加载MemPrcoFS

以SYS权限执行任意EXE

重置PCILeech

The screenshot shows the PushPin application interface with the following sections highlighted:

- KMD LOADERS:** Contains buttons for Win7x64, Win10x64_3, and Win10x64.
- ACCESS:** Contains buttons for UNLOCK, SYS SHELL (highlighted), MNT FS, and USR SHELL.
- KMD STATUS:** Displays Loaded = 0x7ffe000.
- SYS PID:** Displays lsass.exe = 0x03c8.
- USR PID:** Displays explorer.exe = 0x1a48.
- STATUS:** Displays KMD: Code inserted into the kernel - Waiting to receive execution. KMD: Execution received - continuing ... KMD: Successfully loaded at address: 0x7ffe000.
- PERSISTANCE:** Includes a Source File field with a Browse button, an Enter Destination on Target field, and an EXECUTE button.
- Bottom Buttons:** RST PushPin and KILL CMD.

内核模块加载地址

SYSTEM的lsass.exe地址

用户的explorer.exe地址

PCILeech的执行日志

关闭全部CMD窗口

DMA游戏作弊



云鼎实验室 | 腾讯云安全

```
1 #.....
2 print("初始化 PCILeech VMM ...")
3 vmm_instance = None
4 try:
5     args = ['-device', 'fpga', '-v', '-vv'] # 指定目标为FPGA DMA板
6     vmm_instance = memprocfs.Vmm(args)
7     print("VMM 初始化成功。")
8
9     print(f"正在远程主机上查找进程: {PROCESS_NAME}...")
10    process = vmm_instance.process(PROCESS_NAME)
11
12    if process:
13        print(f"成功附加到远程进程: {PROCESS_NAME} (PID: {process.pid})")
14        try:
15            # 1. 读取宽度和高度
16            width_bytes = process.memory.read(ADDR_WIDTH, 4)
17            height_bytes = process.memory.read(ADDR_HEIGHT, 4)
18            width = struct.unpack("<L", width_bytes)[0]
19            height = struct.unpack("<L", height_bytes)[0]
20            print(f"雷区尺寸: {width} x {height}")
21            # 2. 读取雷区数据
22            # (扫雷游戏在内存中存储时, 上下左右各有一圈边界, 所以是 +2)
23            read_size = (height + 2) * ROW_STRIDE
24            board_data = process.memory.read(ADDR_BOARD_BASE, read_size)
25            # 3. 解析并绘制
26            parse_and_print_board(board_data, width, height)
27 #.....
```

```
C:\Windows\system32\cmd.exe
[REGISTRY] HIVE_ENUM: 0022: 0xffff9a8fbf034000-unknown-MACHINE_HARDWARE
[PLUGIN] LOAD: native module: 'py'
[PLUGIN] PluginManager: Python plugin loaded.
VMM 初始化成功。
在远程主机上查找进程: winmine.exe...
成功附加到远程进程: winmine.exe (PID: 5464)
雷区尺寸: 9 x 9

--- 小透不算透, 微锁不算锁, 辅助不算挂, 没关也算开? ---

  1  2  3  4  5  6  7  8  9
-----
1 | .  X  X  .  .  X  .  .  .
2 | .  .  .  .  X  .  .  .  .
3 | .  .  .  .  .  .  .  .  .
4 | .  .  X  .  .  .  .  .  .
5 | .  X  .  X  X  .  .  .  .
6 | .  .  .  .  .  .  .  .  .
7 | X  .  .  .  .  .  .  .  X
8 | .  .  .  .  .  .  .  .  .
9 | .  .  .  .  .  .  .  .  .

Exit periodic cache flushing
SHUTDOWN COMPLETED (0000017C7A88E040).
TIME: 2025-10-23 13:49:07 UTC.
RUNTIME: 11s.

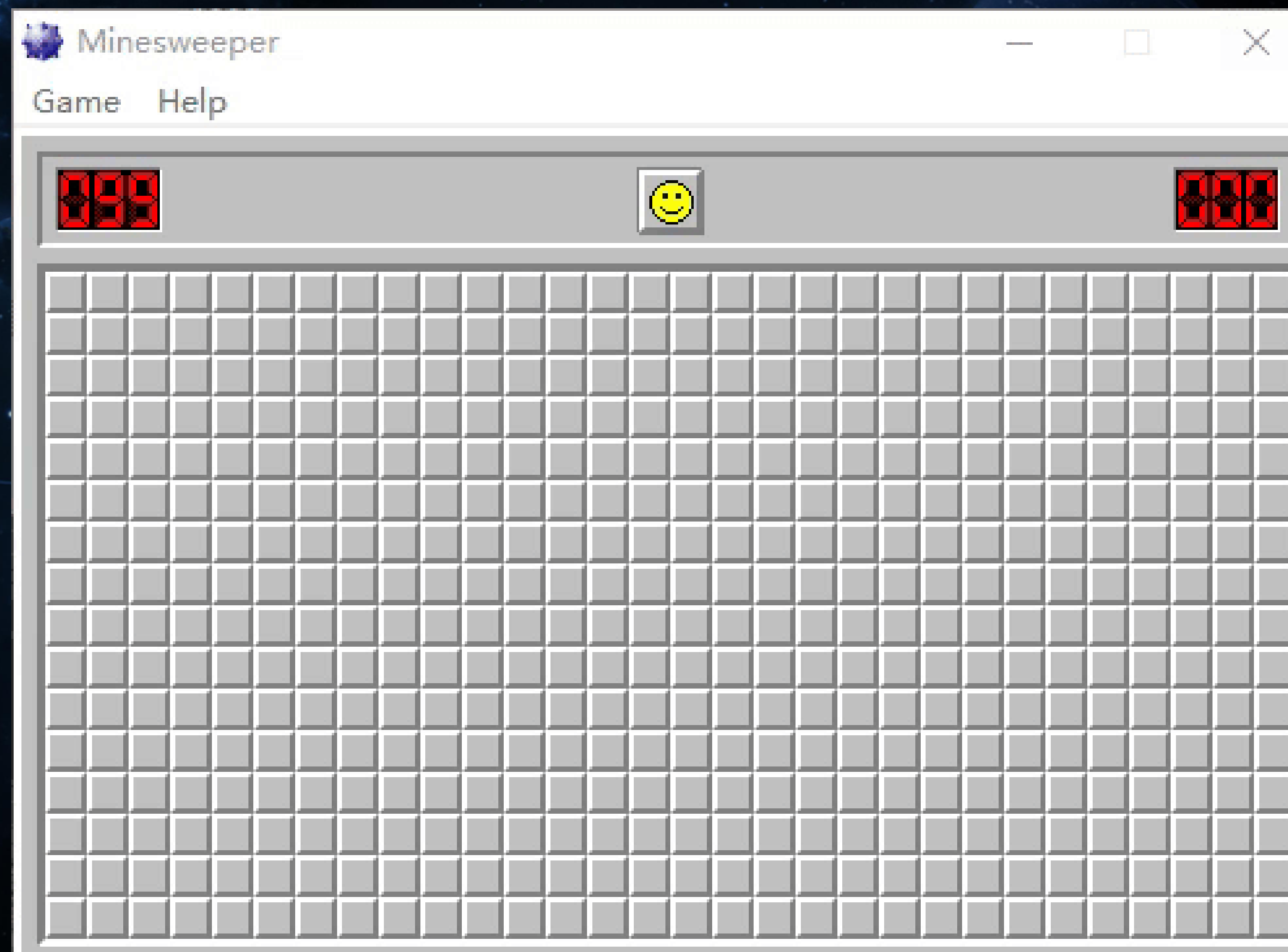
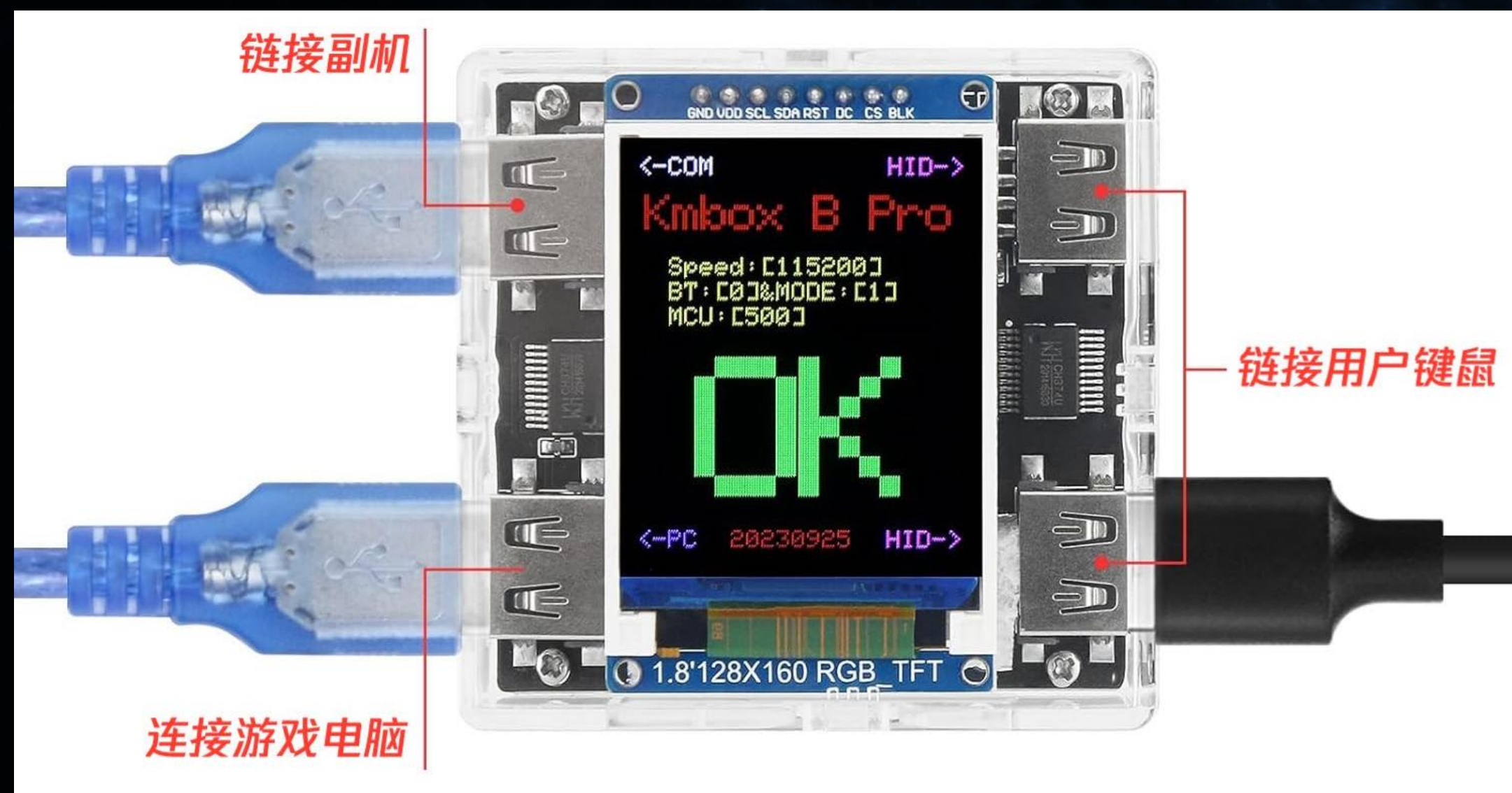
[CORE]
[CORE]
[CORE]
[CORE]

连接已关闭。
```



DMA游戏作弊

1. 使用DMA读取游戏内存，避免传统读内存特征、加载驱动。
2. 在副机进行内存解析、坐标计算。
3. 使用CH9329、ESP32等芯片执行键鼠操作，避免写内存。





THANKS